

SOP – Benutzer- & Zugriffsverwaltung (CFlux)

Version: 1.0 · Stand: 2026-07-13 · Verantwortlich: Anwendungs-Admin / IT-Betrieb

Regelt das Anlegen, Ändern, Rezertifizieren und Deaktivieren von Benutzerkonten sowie die Vergabe von Berechtigungen in CFlux.

1. Zweck

Sicherstellen, dass jeder Benutzer genau die Zugriffsrechte hat, die er für seine Aufgabe benötigt (Least Privilege), und dass Zugänge bei Austritt zeitnah entzogen werden.

2. Berechtigungsmodell in CFlux

- **Rollen** (`UserRole`): **ADMIN** und **USER**.
 - **ADMIN** hat **automatisch vollen Zugriff auf alle Module** – sehr restriktiv vergeben.
 - **USER** erhält Zugriff ausschließlich über **Benutzergruppen**.
- **Benutzergruppen** werden Modulen zugeordnet. Pro Modulzuordnung gibt es vier Stufen: **canView**, **canCreate**, **canEdit**, **canDelete**.
- Ein Benutzer kann Mitglied mehrerer Gruppen sein (Rechte werden kombiniert).
- Referenz: **docs/MODULE_PERMISSIONS.md**, **docs/FIX-MODULE-PERMISSIONS-MULTI-GROUP.md**.

3. Grundsätze

- **Least Privilege**: Nur benötigte Module/Stufen vergeben.
- **Named Accounts**: Keine geteilten Konten; jeder Benutzer ist persönlich zugeordnet.
- **ADMIN-Rolle** nur für IT/Anwendungs-Admins, dokumentierte Begründung.
- **Vier-Augen-Prinzip** bei Vergabe der ADMIN-Rolle.
- Jede Rechteänderung wird im **Audit-Log** protokolliert.

4. Ablauf: Benutzer anlegen (Onboarding)

1. Anforderung mit Vorgesetzten-Freigabe (E-Mail/Ticket) liegt vor.
2. Admin → Benutzerverwaltung → Benutzer anlegen (Name, E-Mail, Personalnummer).
3. Passende **Benutzergruppe(n)** zuweisen – keine Einzelrechte an Personen kleben.
4. Rolle standardmäßig **USER**. **ADMIN** nur nach separater Freigabe.
5. Erst-Passwort setzen bzw. Einladung/Reset-Link versenden; Benutzer ändert Passwort beim ersten Login.
6. Zuordnung dokumentieren (wer, welche Gruppen, Freigabe durch wen, Datum).

5. Ablauf: Rechte ändern

1. Anforderung mit Begründung und Freigabe.
2. Gruppenzugehörigkeit anpassen (bevorzugt) statt Einzelrechte.

3. Änderung dokumentieren; bei Ausweitung auf sensible Module (HR, Lohn, Rechnungen) Freigabe des jeweiligen Fachbereichs einholen.

6. Ablauf: Benutzer deaktivieren (Offboarding)

Ziel: Zugriff **am Austrittstag** entzogen.

1. Meldung von HR/Vorgesetztem über Austritt/Sperrung.
2. Admin → Benutzer **deaktivieren** (nicht löschen – Historie/Zeiteinträge bleiben).
3. Aktive Sessions entwerten: bei Verdacht/kritischem Fall **JWT_SECRET** rotieren (invalidiert alle Tokens – nur im Notfall, siehe SOP Security Incident Response).
4. Gruppen-/Modulrechte entziehen.
5. Offene Aufgaben/Genehmigungen (Workflows) neu zuweisen.
6. Deaktivierung dokumentieren.

7. Default-Admin

- **admin@timetracking.local** / **admin123** ist der Auslieferungs-Admin.
- **Nach Inbetriebnahme:** Passwort ändern, in ein persönliches Admin-Konto überführen oder deaktivieren. Kein Dauerbetrieb mit dem Default-Konto.

8. Rezertifizierung (halbjährlich)

- ☐ Liste aller aktiven Benutzer + Gruppen exportieren/sichten.
- ☐ Alle **ADMIN**-Konten prüfen: noch berechtigt? Begründung aktuell?
- ☐ Verwaiste Konten (kein Login seit X Monaten) deaktivieren.
- ☐ Gruppen-Modulrechte gegen Rollenkonzept abgleichen.
- ☐ Ergebnis dokumentieren (Datum, Prüfer, Maßnahmen).

9. Referenzen

- **docs/MODULE_PERMISSIONS.md**, **docs/FIX-MODULE-PERMISSIONS-MULTI-GROUP.md**
- **docs/ADMIN-MANUAL.md**
- SOP Passwort-Reset, SOP Security Incident Response, SOP Datenschutz